

한국서부발전(주) 상임감사위원 시 정·개 선·주 의(기관) 요 구

제 목	출입관리시스템 프로그래밍 오류 수정 필요
소 관 부 서	■■■■■처 □□□□□실
조 치 부 서	■■■■■처 □□□□□실
구 분	정보처리
내 용	

1. 업무 개요

우리 회사에서 운영하는 ‘출입관리시스템’은 외부 고객이 내방할 때 이용하는 사외 시스템으로써 사외 홈페이지의 발전소 출입신청을 통해 외부 신용정보 회사에서 제공하는 실명확인 절차를 거친 후 방문자의 신상 정보¹¹⁾ 제공에 따라 방문자를 접수하고 있다. 출입관리시스템은 방문자와 내부 직원 간 출입을 사전 승인하는 절차를 전산화한 웹사이트로써 ① 방문자 a가 내부 직원 A를 지정하여 방문일정을 신청하고 ② 신청이 완료되면 내부 직원 A는 사내 홈페이지 업무망에서 신청서를 확인하며 ③ 내부 직원 A는 방문자 a의 신상과 방문일정을 승인¹²⁾하는 것으로 모든 절차가 종료된다. 이 과정에서 방문자 a의 정보는 내부 직원 A를 제외하고는 누구도 열람할 수 없도록 설계되어 있다.

2. 관계규정 및 판단기준

11) 성명, 소속, 휴대폰 번호, 차량 번호,

12) 발전소 출입신청은 사외 홈페이지에서 이루어지고 출입관리시스템은 사내 홈페이지 업무망에서 열람이 가능

「개인정보보호법」 제29조(안전조치 의무) 내지 동법 시행령 제30조(개인정보의 안전성 확보 조치)에 따라 개인정보가 분실·도난·유출·위조·변조 또는 훼손되지 아니하도록 내부 관리계획 수립, 접속기록 보관 등 안전성 확보에 필요한 기술적·관리적 및 물리적 조치를 하여야 하고 정당한 개인정보 접근 권한에 대한 부여·변경·말소와 관련하여 시스템이 운영되어야 하며 개인정보에 대한 접근을 통제하는 조치를 마련해야 한다.

3. 감사결과 확인

그런데 감사 결과 우리 회사의 출입관리시스템에서 일정 시간(30분)이 지난 후 특정한 1개의 발전본부를 방문하기로 신청한 방문자의 정보를 모두 열람할 수 있도록 조회되는 기술적인 오류를 확인하였다.

일반적으로 접속자가 웹사이트에 로그인을 하면 Session 정보¹³⁾라는 임시 데이터를 생성하는데, 웹사이트는 생성된 Session 정보를 확인하여 접속자를 승인된 사용자로 인식하고 승인된 사용자는 일정 시간 내에는 별도의 로그인 절차가 하지 않아도 자유롭게 웹사이트 내의 웹페이지를 오고 갈 수 있게 된다.

그래서 Session 정보를 제대로 설정하지 않거나 웹사이트 설계를 부실하게 하면 정보 침해나 보안 문제를 일으킬 가능성이 존재하는데, 출입관리시스템에서는 일정 시간이 지나면 휘발되도록 설정되어 있음에도 Session 정보가 휘발된 후에 자동으로 로그아웃되는 기능을 구현하지 않았다. 이에 시스템 설계와 다르게 30분 후에 방문객 조회 메뉴를 선택했을 때 특정 발전본부의 방문객이 모두 조회되도록 프로그램을 구현한 사실을 발견하였다.

이처럼 방문자의 신상 정보가 목적과 다르게 취득될 위험이 존재하는 것을

13) 사용자 인증 시 사용권한 취득을 위해 생성되는 고유한 식별정보로 웹사이트 고유ID, 성명, 소속, 권한범위 등이 포함되고 흔히 쇼핑몰의 장바구니 기능에 활용됨

확인함에 따라 설계와 다르게 구현된 기술적인 오류로 인하여 고객 신상 정보 관리의 적정성이 훼손되었다.

관련자 주장 및 판단

■■■■■실 업무 담당자는 감사 지적사항에 대해 즉시 조치하였으며 그 외에 다른 오류에 대해서도 조사하여 개선하겠다고 하였다.

조치할 사항

■■■■■처장은 ① 출입관리시스템의 기술적 오류를 수정하시고 (시정), ② 향후 정보시스템의 준공 검사 시 Session 정보에 대한 시스템 테스트를 필수로 시행하도록 업무 절차에 반영하시며 (개선), ③ 정보시스템을 운용하는 부서원을 대상으로 교육을 시행하시기를 바랍니다. (부서주의)